牧田（中国/昆山）有限公司
信息安全策略

信息安全基本方针
信息安全制度

制定日 ： 2006 年 11 月 1 日
实施日 ： 2006 年 11 月 1 日

承　认	点　检	作　成
川瀬	今井	高篠

信息安全委员会

履历

版本	管理编号	改订日	内容
1	-	06/11/1	初版
2	-	07/1/1	8.3 增加教育记录返回时间；8.4 等增加监查、报告；9.1 等 订正部分文字；9.2 增加“每年至少一次”；
3	-	07/9/13	12 信息安全委员会常务委员名单变更
4	-	08/07/15	12 信息安全委员会常务委员名单变更
5	-	08/09/5	4.增加机密信息定义；5.增加机密信息的管理
6	-	10/04/07	１３ 信息安全委员会常务委员名单变更
7	-	10/7/7	１３ 信息安全委员会常务委员名单变更
8	-	12/4/9	6.5 增加 ISO27001 8.3 信息资产主管部门增加“内部监查室”； 9.3 增加 将《信息安全策略》列入年度教育计划中 13 信息安全委员名单变更
9	-	14/4/10	13 信息安全委员会常务委员名单变更
10	-	14/10/28	9.3 增加将【信息安全 10 条】列入新人教育计划中
11	-	17/2/14	5.机密信息的管理:机密信息安全规定改为机密信息管理程序书.
12	-	18/2/26	修订 9.4 监督、评价以及改订
13	-	18/12/25	修订 3.3、6.5、9.3、9.4、9.5，详见正文
14	-	19/3/29	修订 9.7 追加对信息安全策略违反者的处罚明细
15	-	21/01/13	信息定义里追加人工智能相关
16	-	21/6/22	追加附页《信息安全审核管理规定》
17	-	23/3/21	明确新人教育的时机、追加 MJ 集团策略关于风险应对的内容。
18			
19			

目录

第１章　信息安全基本方针……1
第２章　信息安全制度……2
１　主旨……2
２　适用范围……2
３　对象……2
３．１　高级管理层的职责……2
３．２　员工的职责……2
３．３　对于供应商……2
４　定义……2
５　『机密信息的管理』……3
６　『信息安全策略』的构成及定位……3
６．１　信息安全基本方针……4
６．２　信息安全制度……4
６．３　信息安全规定……4
６．４　信息安全实施记录……4
６．５　有关法规・有关标准……4
７　组织……4
７．１　信息安全责任者（总经理）……5
７．２　信息安全委员会……5
７．３　信息安全常务委员……5
７．４　信息安全推进委员……5
７．５　事务局……5
８　信息安全委员会组织图及构成……5
８．１　信息安全委员会组织图……5
８．２　信息安全委员长……6
８．３　信息安全常务委员……6
８．４　信息安全推进委员……6
８．５　事务局人员……6
９　信息安全委员会的职责……6
９．１　信息安全管理的规划……6
９．２　『信息安全策略』文件的发行责任……6
９．３　社内教育、实施以及效果确认……6
９．４　监查、评价以及改订……6
９．５　向总经理报告……7
９．６　总经理向 MJ 信息系统中心报告……7
９．７　对『信息安全策略』违反者的处罚……7
１０　信息安全管理……8
１０．１　风险分析・改善……8
１０．２　制定规定……8
１０．３　发布规定……8
１０．４　教育・实施・确认效果……8
１０．５　监查・评价……8
１１　信息安全规定……9
１２　信息安全受到侵害时的应对……9
１３　信息安全委员会常务委员名单……9

第 1 章　信息安全基本方针

牧田（中国/昆山）有限公司（以下合称公司）始终站在客户的立场，向着“为人类的生活和居住做贡献的国际性综合性企业”的目标不断努力。

公司重视客户信任，不论是客户信息，还是公司内部信息都被视为公司的重要资产来加以保护，故制定本『信息安全策略』，规范运作，加强管理。

基于以上原则，公司全体干部、员工在日常工作中必须严格遵守以下方针。

1. 公司遵守国家颁布的信息安全相关法律、法规。

2. 公司设立信息安全责任人，成立信息安全委员会。

3. 公司将采取措施，避免信息资产的非法使用、流失、破坏、泄露事件的发生。

4. 公司将对全体员工实施教育活动，使其认识到信息资产的重要性。

5. 公司实施定期的信息安全监查活动，使其不断改善、持续发展。

6. 公司万一发生信息安全上的问题，必将迅速查明原因，将极力控制伤害的扩散。

第 2 章　信息安全制度

1　主旨

为了信息安全管理制度的确立、实施、维持，制定必要的制度、责任、对策，使信息安全管理能有效的运行下去。

2　适用范围

『信息安全策略』的适用范围是与公司信息资产有关的人・物・环境等资源。
公司的相关系统构成参见有关资料。

3　对象

『信息安全策略』的对象是所有我公司信息资产的使用者。但是根据具体不同的安全对策内容，对象有所不同，请以各信息安全规定中明确的对象为准。

（１）　公司的干部及员工
（２）　公司下属子公司的员工
（３）　合作伙伴（供应商、OEM厂家、销售公司、外协公司等）

３．１　高级管理层的职责

主管、副经理、经理、副总经理、总经理

（１）　批准『信息安全策略』；
（２）　在公司范围积极推进信息安全管理；
（３）　推动对所有员工进行『信息安全策略』的强制培训，以提高员工的信息安全意识。
（４）　对于信息安全缺陷高级管理层必须及时调查原因并将重要事项汇报到牧田日本（MJ）总部的信息系统中心，以便尽早进行改善。

３．２　员工的职责

科长以下所有员工

（１）　员工只能在被允许的范围内使用公司的信息资产，禁止因私使用。
（２）　为维护公司利益、满足客户要求，员工必须同意并遵守『信息安全策略』。
（３）　员工一旦发现或怀疑有违反『信息安全策略』的事项发生时，必须及时向管理层、信息系统中心或内部监查室报告。

３．３　对于供应商

本『信息安全策略』的所有权为MCC/MKC所有，只能在牧田集团内部使用。但是，如果管理层从牧田集团的经营和信息安全考虑认为有必要的时候，也可以将本IT安全防范方针提供给供应商、经营合作方以及公司外部咨询顾问，但前提是在提供本方针前必须签订保密协议。

4　定义

- 信息：包含/不限于以下方面：用音频、视频、书面、磁带、电子以及光盘格式储存的所有与调研、知识产权、企业经营和产品发展、实际测试和评价结果、人工智能相关的输入信息、学习结果以及评价资料、销售、市场营销及经营计划、客户和供应商、供应链、制造过程、分销渠道、财务、人事、咨询、合伙、合同以及收购等活动相关的信息。

- 机密信息：是指除了决算公布/新产品发表等公开发表的信息之外，所有本公司独有的信息。包括：（1）技术情报—成品/部品图纸、自主设计的设备治具图纸、开发设计情报、生产技术情报等。（2）公司经营状况情报—决算状况（未公开部分）、生产管理情报（从接到定单到成品/部品出货的各类数据、成品/部品的价格等）、检查情况（进货、成品及出库检查规格等）、体系文件、组织图、个人情报等。

- 风险管理：包括所有能够及时发现和防止当公司资产遗失、被窃取、损毁、更改或无法取得时导致公司经营受到威胁和影响的可能性的各项措施和手段。这些潜在的风险可能是人为故意的（例如：由心存不满的员工、竞争对手、黑客、新闻机构、外国政府等人为造成的），也可能是非故意的意外事件（例如：硬件或软件发生故障、自然灾害、没有充分进行维护或是操作失误导致的风险）。

5 机密信息的管理

机密等级区分
机密等级 1——只能对个别人员展示或提供的信息
机密等级 2——只能对公司内特定部门、公司外特定对象展示或提供的信息
机密等级 3——只能对公司内部人员展示或提供的信息

机密信息必须做上相应标识。

各类机密信息的管理，必须遵守公司程序书[机密信息管理程序书]

6 『信息安全策略』的构成及定位

『信息安全策略』是对总共4层管理文件中面向全公司的上 3 类文件的统称。
基本方针是可对外公开的文件。
以下文件作为非对外公开性社内机密文件。

・信息安全制度

・信息安全规定

・信息安全实施记录

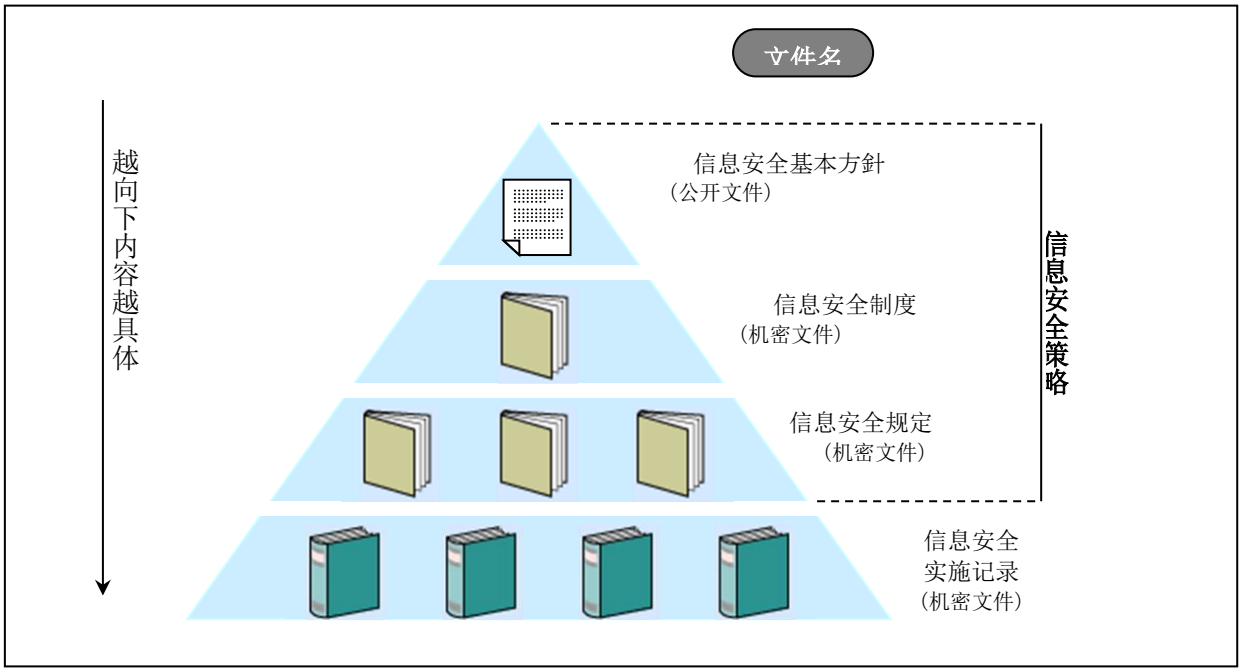

图 1　信息安全策略相关文件的构成

6．1　信息安全基本方针

信息安全基本方针（下称“基本方针”），『信息安全策略』中最上层最基础的文件。

6．2　信息安全制度

信息安全制度（下称“制度”），基本方针之下的文件。描述公司信息安全管理制度，据此建立下一层的具体规定标准。

6．3　信息安全规定

信息安全规定（下称“规定”），制度之下描述具体项目的管理方法。

6．4　信息安全实施记录

信息安全实施记录（下称“记录”）对于具体规定的发行、教育、实施的记录。

6．5　有关法规・有关标准

ISO27001、SOX法案、ISO9002的有关精神、中华人民共和国网络安全法。

7 组织

公司通过以下组织执行信息安全管理。

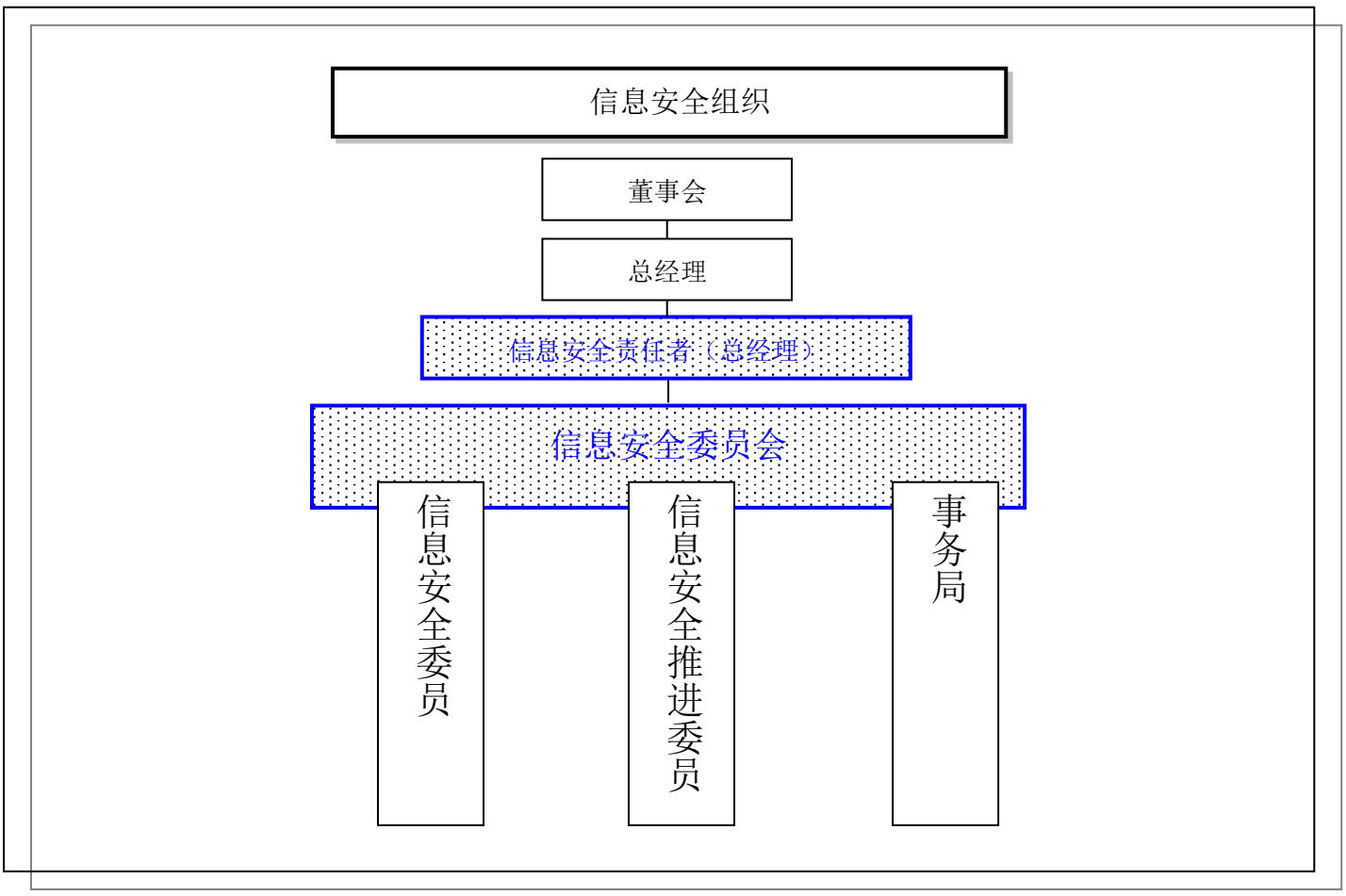

图 2　信息安全组织图

７．１　信息安全责任者（总经理）

信息安全责任者由董事会成员总经理担任，是公司信息安全管理的最高责任人。
信息安全责任者的职责是确立信息安全的方向及战略性决策。

７．２　信息安全委员会

为正常开展信息安全管理而设立的组织，制定和推进公司的信息安全管理。

７．３　信息安全委员

制定和发布公司信息安全管理的有关方针、制度、规定。

７．４　信息安全推进委员

教育和实施信息安全管理的有关方针、制度、规定。

７．５　事务局

推进信息安全委员会的日常管理事务。

8　信息安全委员会组织图及构成

８．１　信息安全委员会组织图

信息安全委员会构成如下图：

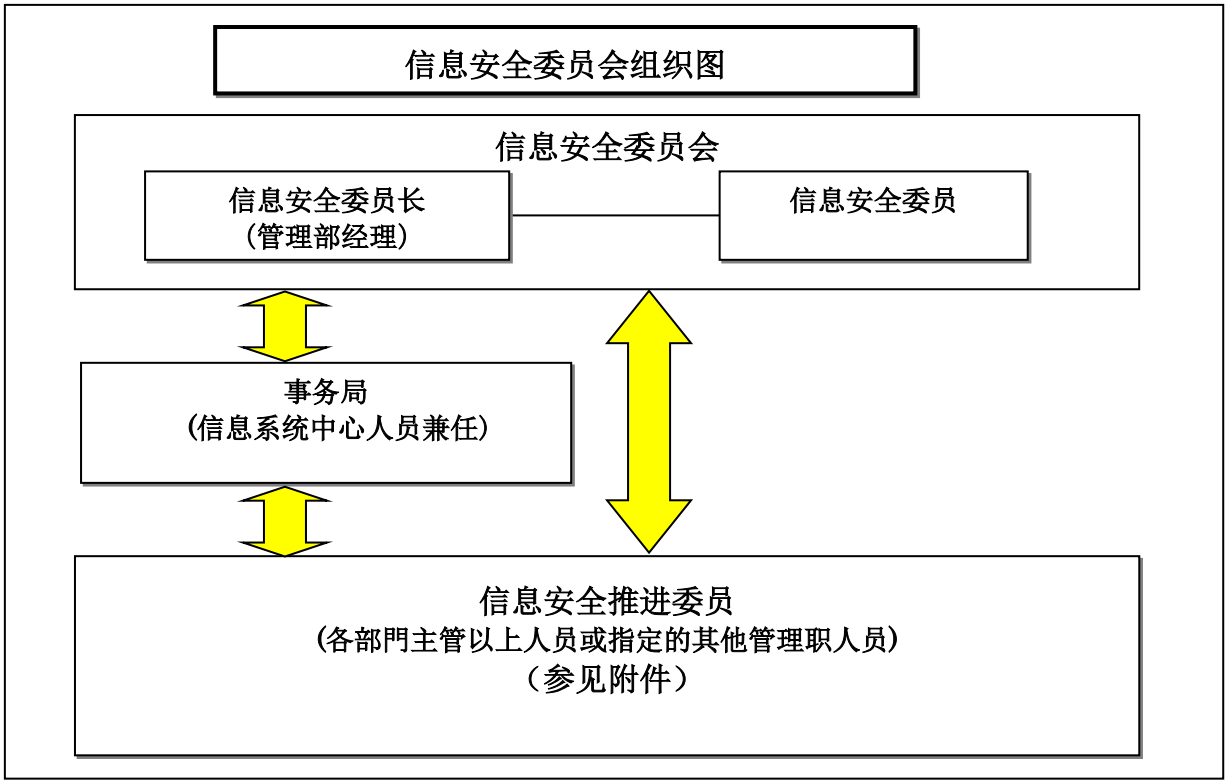

图 3　信息安全委员会组织图

8．2　信息安全委员长

信息安全委员长由管理部经理担任。

8．3　信息安全委员

信息安全委员由信息资产主管部门（管理部、内部监查室、生产管理部）推荐人员担任。

信息安全委员的职责，起草并审议在全公司范围内实施的信息安全有关规定；以及向信息安全委员会提供议题（社内、社外发生的信息安全现象的处理方案等）。

8．4　信息安全推进委员

由各部门主管以上人员（一个部门至少一人）担当，也可指定其他管理职人员担当。

信息安全推进委员的职责，根据信息安全委员发布的规定，推进在本部门内的信息安全活动的教育、实施；以及收集信息安全管理方面的意见和建议，向信息安全委员会提出。

8．5　事务局人员

事务局由信息系统中心兼任，负责信息安全委员会的会议召开，『信息安全策略』文件资料的起草、整理、发行、保管等事务性工作。

9 信息安全委员会的职责

信息安全委员会主要职责如下：

9．1　信息安全管理的规划

信息安全推进委员根据信息安全委员会制定并发布的信息安全管理相关规定，在规定期限内推进部门内部的教育、实施。同时将这些规定实施后的负面风险反馈给信息安全委员会，以便更新『信息安全策略』或者重新考虑规定的教育、实施方法。

9．2　『信息安全策略』文件的发行责任

信息安全委员会的所有『信息安全策略』文件的发行都必须得到信息安全责任者的承认，并及时地发布在内部网站上，以Email通知给相关部门的推进委员。

9．3　社内教育、实施以及效果确认

信息安全推进委员根据『信息安全策略』开展持续的社内教育，将《信息安全策略》及[信息安全10条]列入年度教育计划及新人教育计划中，以提高员工对信息安全的认识。

信息安全推进委员在接到新版『信息安全策略』后，一个月内完成教育落实工作，并保留相关教育记录。

*信息安全教育内容查询路径：信息窗-信息安全委员会-信息安全政策。

9．4　监查、评价以及改订

信息安全委员会根据信息安全推进委员的反馈以及信息系统中心的年检活动、月报告、年报告，并结合中华人民共和国信息安全相关法规对现行『信息安全策略』进行评估，必

要时修改规定。信息安全策略的修订内容需要符合集团信息安全策略,修订内容经总经理承认后，还需要将变更内容邮件联络给MJ情报系统部确认变更部分是否符合集团策略.符合后,方可发行.

9．5　向总经理报告

信息安全委员会每年将信息安全的维持・管理状况、信息安全方面发生的问题以及应对的结果向信息安全责任者（总经理）报告；如发生信息安全紧急事件的，应当及时向信息安全责任者(总经理)报告。

9．6　总经理向MJ信息系统部门报告

信息安全责任者（总经理）每年将信息安全的维持・管理状况、信息安全方面发生的问题以及应对的结果向MJ总部报告；

9．7　对『信息安全策略』违反者的处罚

对于违规者，

信息安全委员会判定员工是否违反『信息安全策略』，违反规定时，视情节公司将根据《就业规定》处理，其中包括处分、罚款、解雇，必要时追究其法律责任。

处罚明细如下：

因故意或过失,给公司造成经济利益损失不足人民币1000元时，给予口头警告处分；

因故意或过失,给公司造成经济利益损失达到人民币1000元以上时，给予书面警告处分；

因故意或过失，给公司造成经济利益损失达到人民币3000元以上时，给予降级减薪、降职降级处分；

因故意或重大过失，泄露公司机密，或企图泄密时，属于严重违纪，公司将给予违纪解除合同处分，视情节轻重决定是否劝告离职或直接辞退，情节特别严重或影响恶劣者将给予以公示公告,必要时追究其法律责任。

１０　信息安全管理

为持续信息安全的管理，公司按照以下方式推进信息安全管理：

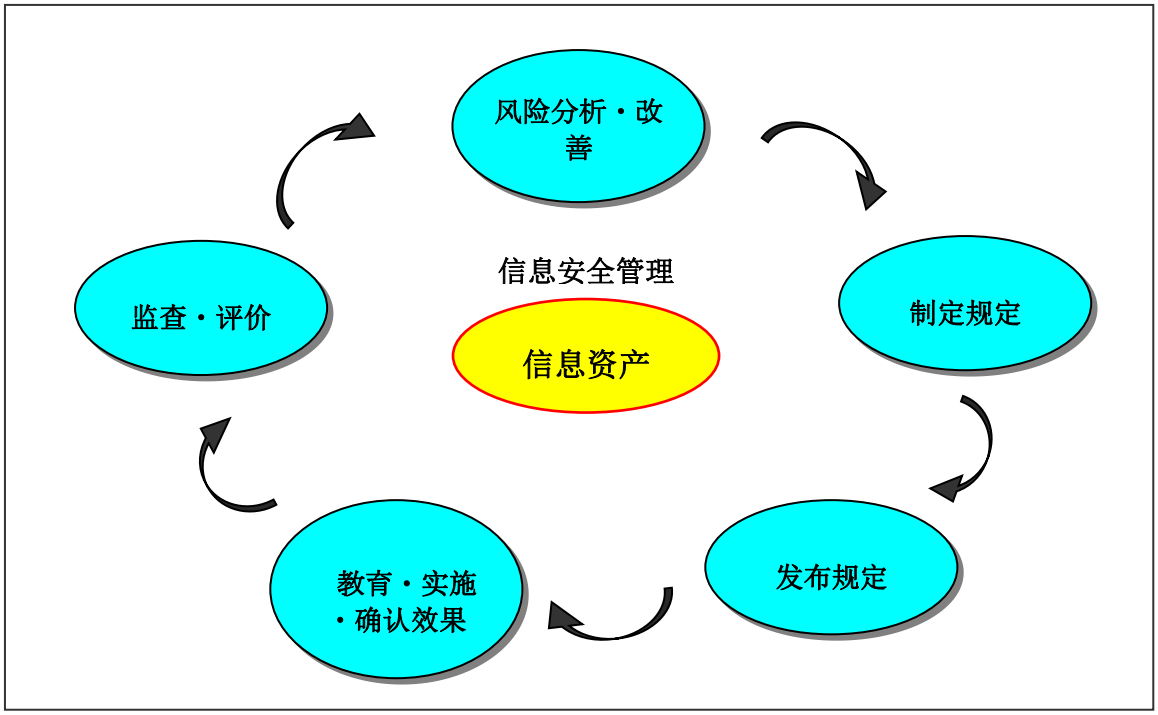

图４　信息安全管理循环图

１０．１　风险分析・改善

根据社会动向，明确现行信息资产安全管理中存在的风险（除了与事业继续、业务持续、合规性有关的风险外，还应该包含信息系统遭受到网络攻击时的侵害风险，同时也包含因内部不正当的行为造成的信息泄露或者系统停机），制定改善计划及对策手段，并根据计划实施。关于抑制风险对策及运用，信息安全推进委员负责在社内进行周知教育，水平展开以提高意识。结果向总经理作年度报告。

１０．２　制定规定

『信息安全策略』的制定、定期复审（每年至少一次）由信息安全委员会进行。

１０．３　发布规定

对于发布的『信息安全策略』，信息安全推进委员必须按计划落实执行。

１０．４　教育・实施・确认效果

公司所有员工必须接受信息安全的教育；同时当员工发现信息安全事故或问题时，有义务向信息安全推进委员报告。

１０．５　监查・评价

通过信息系统中心的内部检查、品质内审等途径发现信息安全管理中存在的问题，各部门在做出改善的同时，通报给所在部门的信息安全推进委员，必要时向信息安全委员会提出修改规定的建议。

由委员会组织，事务局监督内审员每年对各部门实施1次信息安全内部审核，以便保障公司信息安全管理体系得到有效实施和保持。具体操作参照附件《信息安全审核管理规定》。

１１　信息安全规定

『信息安全策略』分为「信息安全基本方针」、「信息安全制度」、「信息安全规定」3大类管理，「信息安全规定」是根据「信息安全制度」的原则，为保护信息资产，将员工必须遵守的事项尽可能具体地罗列出来而形成的文件。

１２　信息安全受到侵害时的应对

公司信息安全受到侵害时，信息安全委员会必须快速做出应对的方法，必须将损害降低到最小、必须尽一切可能控制影响的扩散。

１３　信息安全委员会委员名单

管理部经理
内部监查室科长
生产管理部部门长
生产管理部顾问/副经理
生产管理部信息系统中心科长

附页：

信息安全审核管理规定

1、目的

通过内部审核来确认公司信息安全管理体系的运行是否得到有效实施和保持。

2、适用范围

此程序书适用于本公司信息安全体系的信息安全审核。

3、定义

信息安全审核：公司内验证信息安全体系是否有效运行的活动（以下简称“内审”）。

内审员：经过公司内组织的内审员培训而取得资格，得到信息安全负责人任命的人员。

改善事项：内审时发现的不符合事项（需要纠正），包括：

① 未按文件规定执行，并有可能造成机密信息泄露或重大损失。

② 除①以外的，有可能引起较轻后果的未按文件规定执行的现象普遍存在（3 件以上）

③ 对过去发生的问题，未实施有效的对策，有再发的可能。

④ 文件规定本身不健全或有缺陷，并造成了机密泄漏的发生。

有效性问题（A）：现行做法（规则）没有问题，但通过改善现在正在实施业务的作业方法，可使现有业务的机密遵守度更高，体制更加有效。

符合性问题（B）：

① 实际操作未按文件要求执行（重度）。

② 实际操作方法未及时更新至文件中（轻微）。

4、职责

本程序书所述活动，由 ISMS 委员会负责组织实施。

4.1 ISMS 委员会

作为内审的组织机构，负责：

⑴内审方案的策划

⑵组织内审实施

⑶内审相关报告的确认

⑷总结内审结果，并报告信息安全负责人

⑸组织召开内审总结会

⑹组织实施内审员教育

4.2 ISMS 委员会委员长

由 ISMS 委员会推选出的人员作为内审的总责任者，负责：

⑴ 内审方案的承认

⑵ 内审相关报告的承认

4.3 内审员

(1)编制“ISMS 内审结果通知书”（添附 1）

(2)内审项目检讨、计划实施内审

(3) 根据“ISMS 内审改善报告书”（添附 1）的内容对指出的改善事项，实施改善内容的确认及效果的验证。

(4)审查员不得将审查过程中得到的信息以非审查为目的地公开。

4.4 ISMS 事务局

由信息安全委员担任，负责：

⑴ 内审相关工作联络

⑵ 内审相关资料的准备

⑶ 内审相关表单的发行、回收及保管

⑷ “ISMS 内审改善报告书”（添附 3）的发行和纳期管理

4.5 被审部门

（1）安排能够代表部门应对内审的人员，提供必要的场所、文件资料等，配合内审工作。

（2）对提出的改善事项，实施原因分析及对策。

5、程序 （参见附页 1 信息安全审核流程图）

5.1 内审方案的策划

5.1.1 每年 3 月，ISMS 委员会应策划下年度内审方案经委员长确认并报告总经理进行确定。内审应确保每个部门每年至少进行一次，覆盖本公司信息安全管理体系的所有过程。

5.1.2 内审策划包括以下内容:

（1）年度审核计划编制，有关审核组组建原则如下：

①审核组设主/副审核员，主审由内审员担当，副审由信息安全委员担当。整个审核过

程包括审前检讨，实施审核由 2 名审核员共同进行，审核组员不审核本岗位或自己部

门内类似业务相关科室的工作；

②内审员需经公司内组织的内审员培训合格，具备内部质量管理体系审核资格。

（2）内审相关账票的确定

针对内审所有相关账票（年度内审计划表、ISMS 内审改善报告书、ISMS 内审结果通知书、ISMS 内审项目表，详细参见 6.相关账票），ISMS 事务局在作成年度策划案时，要确认其是否适用目前的内审方式以及是否某项内容不充分等。确认各内审项目是否符合信息安全策略及机密信息管理程序书的要求、确认上记文件当期内变更的要求是否需要反馈到内审项目中去。

如发现账票不完善，需进行修订/删除/增加。修订/删除/增加的内容需提交 ISMS 委员会确认。

最新表单作为年度内审策划附件，以邮件及会议形式通知相关人员。

5.2 年度内审说明会

由 ISMS 委员会组织，将本年度内审策划内容通过说明会向全体内审员、各部门高层管理干部进行说明。

5.3 内审准备

5.3.1 内审日程安排

（1）事务局根据内审计划，邮件通知主审，协调主审进行事前会议，确定审核事项、审查对象及审查日期。确定后，主审至少提前 3 天联络被审部门并抄送 ISMS 事务局；

（2）各审核员如确实因客观原因需要对内审计划进行调整时，需提前 2 周联系 ISMS 事务局，报 ISMS 委员会确认后实施调整。

5.3.2 内审联络

在内审实施前，主审员联络被审部门负责人具体的审核时间、事前需准备的相关文件

资料等。

5.4 内审的实施

5.4.1 现场审核

审核组的各成员按ISMS内审项目表及审核组事前商讨的追加项目（如有）中的各项内容逐一实施审核，并作好相关记录。但审核组也可根据各部门业务的实际情况，临时增加/变更审核项目。

审查分为面谈和现场确认两个部分，前半部分通过询问，记录下被审部门回答的内容；后半部分针对回答的内容进行现场确认，是否符合。

5.4.2 审核组内部讨论

现场审核结束后，由审核组进行内部讨论，初步确定“指出事项”、“发现事项”及问题类型后，并记录在“ISMS 内审结果通知书”中。

5.4.3 内审结果的说明

审核组将“ISMS 内审结果通知书”中的“指出事项”及“发现事项”逐一向被审部门说明，在得到理解之后，由被审部门负责人或内审应对责任者签字确认。

如果在预定的审核时间内，审核员与被审部门对问题的认识不能达成一致，双方均可提出将问题提交 ISMS 委员会讨论决定，并在“ISMS 内审结果通知书”中注明。

5.4.4 审核时间

应尽量在 2 小时内完成 5.4.1~5.4.3 的工作，若因故需要延长审核时间或另外再安排时间时，由内审员与被审部门协商处理，处理结果需联络 ISMS 事务局。

5.5 内审结果的作成

内审结束后，审核组在 SCP 系统中作成“ISMS 内审结果通知书”，并于内审实施结束后的三个工作日内提交。

内审结果审批完成后，系统自动发行“ISMS 内审改善报告书”，交由被审部门进行对策。

5.6 改善实施

5.6.1 改善事项及效果验证

（1）被审部门应于 1 个月内分析内审时指出的“指出事项”的产生原因，并采取对策，将其结果记入“ISMS 内审改善报告书”，由部门经理及部门长承认后返回审核组确认。

（2）在“ISMS 内审改善报告书”回复期限内来不及对策时，可邮件提交改善计划书，并由部门经理及部门长承认后返回给审核组确认。

（3）由于某种原因而暂时无法采取对策时，应在“ISMS 内审改善报告书”里说明不能对策的原因，并由部门经理及部门长承认后返回审核组。

（4）审核组通过审核“ISMS 内审改善报告书”或现场的实际情况，s 确认被审部门的原因分析、对策是否妥当，并要进行效果验证。若效果验证时被确认为对策无效，应委托

ISMS 事务局再次发行“ISMS 内审改善报告书”,要求被审部门重新对策。

5.6.2 改善事项纳期管理

ISMS 事务局对被审部门返回“ISMS 内审改善报告书”进行跟催确认。

如在设定期限内超过一周未回复，事务局以邮件形式联络被审科室主管；如超过一月未回复，事务局以邮件形式联络被审部门副经理以上。

对超过纳期 1 个月以上未回复的“ISMS 内审改善报告书”，由事务局上报信息安全委员会并检讨要求被审部门负责人向信息安全委员会进行延期原因及纳期的汇报。

5.7 内审实施情况总结及报告

5.7.1 内审总结及报告

ISMS事务局根据审核组提交的报告，作成内审（年度）总结报告，经过委员会内部讨

论修改后向信息安全负责人报告。

5.7.2 内审总结会

『内审总结报告』经信息安全负责人批准后，由 ISMS 委员会组织召开内审 1 年 1 次的总结会（由全体内审员、信息安全推进委员及各部门主管以上人员参加），对『内审总结报告』中内审实施的问题点、今后的内审改善方向、本年度信息安全委员会活动结果、下一期信息安全委员会活动计划等作详细说明。

6、相关帐票

“ISMS 内审结果通知书/内审改善报告书”